Universidad Nacional de Costa Rica
Escuela de Informática
Ingeniería en Sistemas de Información

Curso: Administración de Bases de Datos
Tema: Seguridad y Auditoría de Bases de Datos

Controles para Riesgos de Confidencialidad

Tareas del administrador de Bases de Datos

Marco de controles ISO/IEC 27001:2022 e ISO/IEC 27002:2022 implementado y auditado en Oracle Database 21c Express Edition

Estudiante: Jeimy Espinoza Barquero
Profesor: Johnny Villalobos Murillo

Heredia, Costa Rica · II Ciclo 2026 · Octubre de 2026

Contenido

1. Introducción
2. Marco teórico
3. Metodología y entorno del laboratorio
4. Desarrollo: el artefacto
5. Resultados y evidencias
6. Hallazgos y plan de mejora (Actuar)
7. Conclusiones
8. Uso ético y documentado de inteligencia artificial
9. Referencias

A. Anexo: scripts y archivos de evidencia

Enlaces de entrega

Entregable	Ubicación
Artefacto interactivo (HTML)	https://jeimye.github.io/controles-confidencialidad-dba/
Repositorio Git (scripts y evidencias)	https://github.com/JeimyE/controles-confidencialidad-dba
Video explicativo (5 min)	https://youtu.be/3mNyXkx-qyU

1. Introducción

El administrador de bases de datos (DBA) es el custodio técnico de la información más sensible de una organización: tiene acceso privilegiado a los datos, a sus respaldos y a los mecanismos que los protegen. Por eso, muchas de las amenazas a la confidencialidad pasan por sus tareas diarias: la gestión de cuentas y privilegios, el cifrado, los respaldos, la auditoría o la creación de copias para desarrollo.

Este trabajo diseña e implementa un marco de controles basado en el Anexo A de ISO/IEC 27001:2022 y en la guía de ISO/IEC 27002:2022 para mitigar riesgos de confidencialidad en esas tareas. El marco se aplicó sobre una base Oracle Database 21c Express Edition con datos personales ficticios de clientes, sujetos a la Ley N.° 8968 de Protección de la Persona frente al Tratamiento de sus Datos Personales, y se verificó con scripts SQL reproducibles y una batería de pruebas positivas y negativas.

Objetivo general

Diseñar e implementar un marco de controles basado en ISO/IEC 27001:2022 (Anexo A) e ISO/IEC 27002:2022 para mitigar riesgos de confidencialidad en las tareas del administrador de bases de datos, incluyendo una matriz de evaluación y pruebas observables auditables.

Objetivos específicos y dónde se cumplen

Objetivo específico	Resultado en este trabajo
Identificar y clasificar al menos 5 riesgos de confidencialidad (R-CONF).	Sección 4.1: R-CONF-01 a R-CONF-05 con impacto, probabilidad y riesgo residual.
Mapear al menos 12 tareas críticas del DBA.	Sección 4.2: las 12 tareas del enunciado (T-01 a T-12).
Seleccionar y justificar controles del Anexo A 2022.	Sección 4.3: los 15 controles del enunciado y 3 complementarios (A.8.8, A.8.24, A.8.33).
Diseñar una matriz de evaluación 0–4 con evidencia y estado.	Sección 4.5: matriz con niveles asignados a partir de evidencia real.
Proponer y ejecutar pruebas técnicas.	Secciones 4.6 y 5: 25 pruebas, 22 ejecutadas en Oracle 21c XE.

Alcance. La evaluación cubre el esquema de laboratorio `APP_CONF`, sus cuentas y la configuración de la instancia (CDB XE y PDB XEPDB1). En la misma base existen cuentas de otros proyectos académicos; no se modificaron para no afectar esos proyectos, pero se reportan como hallazgos en la sección 6.

2. Marco teórico

2.1 Cambios de ISO/IEC 27001:2022 respecto a la versión 2013

ISO/IEC 27001 define los requisitos de un sistema de gestión de seguridad de la información (SGSI). La edición publicada en octubre de 2022 reorganizó su Anexo A: los 114 controles de la versión 2013, distribuidos en 14 dominios, pasaron a 93 controles agrupados en cuatro temas: organizacionales (cláusula 5, 37 controles), de personas (cláusula 6, 8 controles), físicos (cláusula 7, 14 controles) y tecnológicos (cláusula 8, 34 controles) (ISO/IEC, 2022a). La reducción no significa menos exigencia: varios controles se fusionaron y se agregaron 11 nuevos, entre ellos inteligencia de amenazas (5.7), seguridad en servicios en la nube (5.23), gestión de la configuración (8.9), monitoreo de actividades (8.16), codificación segura (8.28) y tres especialmente relevantes para este trabajo: **eliminación de información (8.10)**, **enmascaramiento de datos (8.11)** y **prevención de fuga de datos (8.12)** (ISO/IEC, 2022b; Cuatrecasas, s.f.).

ISO/IEC 27002:2022 acompaña a la norma con la guía de implementación de cada control y añade atributos que permiten filtrarlos, por ejemplo, el tipo de control (preventivo, detectivo o correctivo) o la propiedad de seguridad que protegen (confidencialidad, integridad o disponibilidad). Las organizaciones certificadas con la versión 2013 tuvieron plazo hasta octubre de 2025 para migrar a la nueva edición (Cuatrecasas, s.f.).

2.2 Mínimo privilegio y separación de funciones en el rol DBA

El principio de mínimo privilegio establece que cada usuario y cada programa deben operar con el menor conjunto de privilegios necesario para su tarea (Saltzer y Schroeder, 1975). En el Anexo A se concreta en el control de acceso (5.15), los derechos de acceso (5.18) y los derechos de acceso privilegiado (8.2). La separación de funciones complementa ese principio: ninguna persona debe concentrar actividades que, combinadas, le permitan abusar del sistema sin ser detectada.

En el rol DBA esto es especialmente delicado, porque la cuenta SYSDBA puede leer cualquier dato, desactivar la auditoría y manipular los respaldos. Oracle ofrece privilegios administrativos acotados, como SYSBACKUP para respaldo y recuperación o SYSKM para la gestión de llaves de cifrado, que permiten delegar esas tareas sin entregar el control total (Oracle, 2021b). En este laboratorio se usaron ambos, junto con roles por función y cuentas de esquema sin inicio de sesión.

2.3 Defensa en profundidad y Zero Trust aplicados a bases de datos

La defensa en profundidad consiste en superponer controles independientes, de modo que la falla de uno no exponga los datos (Joint Task Force, 2020). El modelo Zero Trust lleva esa idea más lejos: ninguna conexión recibe confianza implícita por su ubicación en la red, y cada acceso se autentica, se autoriza y se registra con base en la identidad y el contexto (Rose et al., 2020). Aplicado a una base de datos, implica proteger varias capas a la vez:

- **Red:** cifrado del tráfico y lista de equipos admitidos por el listener.
- **Identidad:** cuentas nominativas, contraseñas robustas y bloqueo por intentos fallidos.
- **Autorización:** roles mínimos y filtrado de filas según el usuario.
- **Datos:** cifrado en reposo y enmascaramiento de columnas sensibles.
- **Detección:** auditoría de cada acceso, incluidos los rechazados.

2.4 Controles técnicos: TDE, enmascaramiento, Data Redaction, RLS/VPD y TLS

Transparent Data Encryption (TDE) cifra los datos en reposo, a nivel de columna o de tablespace, sin cambios en las aplicaciones. Usa una arquitectura de dos niveles: una llave maestra guardada en un keystore externo a la base protege las llaves de cada tablespace. Si alguien copia un archivo de datos o un respaldo, no puede leerlo sin el keystore (Oracle, 2021a).

Dynamic Data Masking es el nombre que usa SQL Server para ocultar datos en el momento de la consulta. En Oracle, la función equivalente es **Data Redaction** (paquete DBMS_REDACT): aplica políticas por columna, de tipo total, parcial o por expresión regular, sin modificar el dato almacenado, y se evalúan según el contexto de la sesión (Oracle, 2021a). No reemplaza al control de acceso: es una capa adicional sobre usuarios que ya tienen permiso de lectura.

Row Level Security, implementada en Oracle como **Virtual Private Database (VPD)** mediante DBMS_RLS, agrega de forma automática una condición a cada consulta para que el usuario solo vea las filas que le corresponden (Oracle, 2021b). Por último, la información en tránsito se protege con **TLS** o con el cifrado nativo de Oracle Net, que se configura en `sqlnet.ora` e incluye verificación de integridad (Oracle, 2021b).

2.5 Prevención de fuga de datos (DLP) y respaldos cifrados

La prevención de fuga de datos busca detectar y bloquear la salida no autorizada de información (control 8.12). En una base de datos, los principales canales de fuga son las exportaciones masivas (Data Pump), las copias hacia tablas propias, los paquetes que permiten enviar datos fuera del servidor (UTL_HTTP, UTL_FILE, UTL_SMTP) y los respaldos. Un respaldo sin cifrar es una copia completa de la base que puede leerse en otro equipo. Por eso el control 8.13 exige proteger su confidencialidad, y RMAN permite cifrarlos de forma transparente con la misma llave maestra de TDE (Oracle, 2021c).

2.6 Registro, monitoreo y correlación (SIEM)

Los controles 8.15 (registro) y 5.33 (protección de registros) piden generar, proteger y conservar evidencias de la actividad. Oracle Unified Auditing centraliza los eventos en UNIFIED_AUDIT_TRAIL, guardada en un esquema protegido contra modificaciones, y DBMS_AUDIT_MGMT permite definir su retención (Oracle, 2021b). Un SIEM (Security Information and Event Management) recolecta esos eventos junto con los de otros sistemas para correlacionarlos y generar alertas; sin esa revisión, los registros solo sirven después de un incidente (Kent y Souppaya, 2006).

2.7 Normativa costarricense: Ley N.° 8968 y su reglamento

La Ley N.° 8968 de Protección de la Persona frente al Tratamiento de sus Datos Personales, firmada el 7 de julio de 2011, obliga al responsable de una base de datos a adoptar las medidas técnicas y de organización necesarias para garantizar la seguridad de los datos (artículo 10) y establece el deber de confidencialidad de quienes intervienen en su tratamiento (artículo 11). También exige eliminar los datos que ya no sean necesarios para su finalidad (artículo 6), reconoce los derechos de acceso, rectificación y supresión del titular (artículo 7) y crea la Agencia de Protección de Datos de los Habitantes, PRODHAB (artículo 15) (Asamblea Legislativa, 2011).

Su reglamento, el Decreto Ejecutivo N.° 37554-JP, detalla esas obligaciones: medidas de seguridad administrativas, físicas y lógicas (artículo 34), análisis de riesgos e inventario de medidas (artículo 36), revisión anual de las medidas cuando se tratan datos sensibles (artículo 37) y notificación de vulneraciones a los titulares y a la Agencia en un plazo de cinco días hábiles (artículos 38 y 39) (Poder Ejecutivo, 2013). La ley sigue vigente; en octubre de 2026 se presentó el expediente 25826, que propone reformar su artículo 10 frente a las filtraciones de datos y se encuentra en comisión (Delfino.cr, 2026).

Los controles de este trabajo responden directamente a esas obligaciones: cifrado y control de acceso (artículo 10), enmascaramiento para quien no necesita el dato (artículo 11), y supresión trazable y purga por plazo de conservación (artículos 6 y 7).

3. Metodología y entorno del laboratorio

El trabajo siguió el ciclo PHVA (Planificar, Hacer, Verificar, Actuar). Cada fase dejó un producto verificable:

Fase	Actividades	Producto
Planificar	Análisis del enunciado, identificación de riesgos R-CONF, mapeo de tareas del DBA y selección de controles del Anexo A.	Secciones 4.1 a 4.4 y el artefacto interactivo.
Hacer	Implementación de los controles en Oracle 21c XE con scripts SQL y RMAN (01 a 10b).	Scripts de implementación.
Verificar	Batería de pruebas por usuario (script 21) y verificación de los 18 controles (script 20).	evidencia_pruebas.txt, evidencia_controles.txt, evidencia_backup.log y capturas.
Actuar	Análisis de hallazgos y plan de mejora para los controles que no alcanzan el nivel 4.	Sección 6.

Entorno

Elemento	Detalle
Motor	Oracle Database 21c Express Edition, versión 21.3.0.0.0, en Windows. Arquitectura multitenant: contenedor raíz CDB$ROOT y base conectable XEPDB1.
Herramientas	SQL*Plus (ejecución de scripts y spool de evidencias), RMAN (respaldo cifrado) y SQL Developer (los scripts son compatibles con su opción Ejecutar script, F5).
Datos	Tabla APP_CONF.CLIENTES con 63 registros ficticios: cédula, nombre, correo, teléfono, provincia, salario y tarjeta. Ningún dato corresponde a personas reales.
Cuentas del laboratorio	U_ANALISTA, U_OPERADOR, U_AUDITOR, U_DBA_JR y U_DESARROLLADOR (nominativas); APP_CONF y APP_CONF_DEV (esquemas sin inicio de sesión); C##BACKUP_OP (SYSBACKUP) y C##KEY_ADMIN (SYSKM).
Escala de madurez	0 Inexistente · 1 Inicial · 2 Parcial · 3 Definido (implementado, documentado y con evidencia SQL reproducible) · 4 Gestionado (además, verificado con pruebas automatizadas). Estado: 0–1 No cumple, 2 Parcial, 3–4 Cumple.

Ajustes al enunciado

- El enunciado menciona `pg_hba.conf` como ejemplo de evidencia; ese archivo es de PostgreSQL. Su equivalente en Oracle es `sqlnet.ora` (TCP.VALIDNODE_CHECKING y TCP.INVITED_NODES), que fue el que se configuró.
- El enunciado nombra Dynamic Data Masking; en Oracle se implementó con Data Redaction (DBMS_REDACT), que es la función equivalente.
- Se agregaron tres controles complementarios porque son los que corresponden a tareas del enunciado: A.8.24 (uso de criptografía) para TDE y respaldos cifrados, A.8.8 (vulnerabilidades técnicas) para el parcheo y A.8.33 (información de prueba) para los clones DEV/TEST.

4. Desarrollo: el artefacto

El artefacto interactivo contiene las seis tablas que pide el enunciado y permite consultar las consultas SQL de evidencia de cada control. Está disponible en https://jeimye.github.io/controles-confidencialidad-dba/. Esta sección reproduce su contenido.

4.1 Tabla de riesgos de confidencialidad

ID	Riesgo	I	P	Inherente	Controles	Residual
R-CONF-01	**Privilegios excesivos y abuso de cuentas privilegiadas** Usuarios con rol DBA, privilegios ANY o grants directos, cuentas por defecto o compartidas leen datos personales sin necesidad de negocio.	5	4	20 · Crítico	A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.5	10 · Alto
R-CONF-02	**Robo de archivos de datos, respaldos o exportaciones sin cifrar** Copia de archivos .DBF, piezas RMAN o dumps de Data Pump fuera del servidor y lectura directa sin pasar por la base.	5	3	15 · Alto	A.8.24, A.8.13, A.8.12	5 · Medio
R-CONF-03	**Exposición de datos personales fuera de su finalidad** Analistas o entornos DEV/TEST ven cédulas, salarios o tarjetas reales; datos conservados más allá de su plazo.	4	4	16 · Crítico	A.5.12, A.8.3, A.8.10, A.8.11, A.8.33	8 · Medio
R-CONF-04	**Intercepción de tráfico y acceso de red no autorizado** Credenciales y resultados viajan en claro por Oracle Net; cualquier equipo de la red puede intentar conectarse al listener.	4	3	12 · Alto	A.8.20, A.8.5	4 · Bajo
R-CONF-05	**Accesos indebidos sin trazabilidad** Sin auditoría, o con registros que se pueden borrar, las lecturas indebidas no se detectan ni se investigan.	4	3	12 · Alto	A.8.15, A.5.33	4 · Bajo

Impacto (I) y probabilidad (P) en escala 1–5; nivel = I × P. Bandas: Bajo 1–4, Medio 5–9, Alto 10–15, Crítico 16–25. El riesgo residual estima la probabilidad tras aplicar los controles.

4.2 Tabla de tareas del DBA

ID	Tarea	Actividades	Frecuencia	Riesgos	Controles	Script
T-01	**Gestión de usuarios**	Alta nominativa con perfil seguro, bloqueo de cuentas inactivas, esquemas dueños sin inicio de sesión	Por solicitud · revisión mensual	R-CONF-01	A.5.16, A.5.18	03, 04
T-02	**Gestión de privilegios**	Roles por función, sin privilegios directos, separación SYSBACKUP / SYSKM	Por solicitud · revisión trimestral	R-CONF-01	A.5.15, A.8.2	02, 04
T-03	**Autenticación**	Perfil de contraseñas, bloqueo por intentos fallidos, solo verificadores 12C	Inicial · trimestral	R-CONF-01 R-CONF-04	A.5.17, A.8.5	04, 09
T-04	**Cifrado TDE**	Keystore unificado, llave maestra AES256, tablespace cifrado, rotación de llave	Inicial · rotación anual	R-CONF-02	A.8.24, A.5.12	01, 03
T-05	**Enmascaramiento (Data Redaction) y VPD**	Políticas DBMS_REDACT por columna y DBMS_RLS por fila	Por cambio de esquema	R-CONF-03	A.8.11, A.8.3	05
T-06	**Respaldo cifrado**	RMAN en ARCHIVELOG con cifrado transparente AES256 y RESTORE VALIDATE	Diario · validación mensual	R-CONF-02	A.8.13, A.8.24	10a, 10b
T-07	**Auditoría**	Políticas unificadas sobre datos, cambios de seguridad, exportaciones y logons fallidos	Continuo · revisión semanal	R-CONF-05	A.8.15	06
T-08	**Parcheo**	Inventario de versión y parches aplicados, plan de actualización	Trimestral	R-CONF-01 R-CONF-04	A.8.8	20
T-09	**Listener y Oracle Net**	sqlnet.ora con cifrado nativo y checksum obligatorios, lista blanca de IP	Inicial · por cambio de red	R-CONF-04	A.8.20	09
T-10	**Eliminación segura**	Supresión a solicitud del titular, purga por plazo, papelera vacía	Por solicitud · mensual	R-CONF-03	A.8.10	07
T-11	**Gestión de logs**	Retención de 365 días, purga automática, registros protegidos en AUDSYS	Diario (job)	R-CONF-05	A.5.33, A.8.15	06
T-12	**Clones DEV/TEST**	Copia con enmascaramiento estático; desarrollador sin acceso a producción	Por refresco de DEV	R-CONF-03	A.8.11, A.8.33, A.8.12	08

4.3 Mapeo de controles ISO con implementación y evidencia observable

Los primeros 15 controles son los que indica el enunciado; los marcados como complementarios se agregaron por la razón explicada en la sección 3.

Control	Implementación en Oracle 21c XE	Evidencia observable (consulta)
A.5.12 Clasificación de la información	Catálogo CATALOGO_CLASIFICACION con niveles Público, Interno, Confidencial y Restringido, más etiquetas COMMENT ON COLUMN. Cada columna sensible tiene una protección asignada.	`SELECT c.columna, c.nivel, rc.function_type FROM app_conf.catalogo_clasificacion c LEFT JOIN redaction_columns rc ON rc.object_name = c.tabla AND rc.column_name = c.columna;`
A.5.15 Control de acceso	RBAC con 4 roles por función (analista, operador, auditor, DBA junior). Ningún privilegio directo a usuarios; el operador no tiene DELETE.	`SELECT grantee, privilege FROM dba_sys_privs WHERE grantee IN ('U_ANALISTA','U_OPERADOR', 'U_AUDITOR','U_DBA_JR');`
A.5.16 Gestión de identidades	Cuentas nominativas con PERFIL_CONF. Los esquemas dueños de datos se crean con NO AUTHENTICATION. INACTIVE_ACCOUNT_TIME de 90 días.	`SELECT username, authentication_type, account_status, last_login FROM dba_users WHERE oracle_maintained = 'N';`

A.5.17 Información de autenticación	PERFIL_CONF: complejidad ORA12C_STRONG_VERIFY_FUNCTION, vigencia de 90 días, historial de 5 contraseñas, bloqueo a los 3 intentos.	`SELECT resource_name, limit FROM dba_profiles WHERE profile = 'PERFIL_CONF' AND resource_type = 'PASSWORD';`
		
		`SELECT username FROM dba_users_with_defpwd;`

A.5.18 Derechos de acceso	Revisión de privilegios efectivos con consulta jerárquica sobre toda la cadena de roles heredados.	`SELECT CONNECT_BY_ROOT grantee AS usuario, granted_role FROM dba_role_privs START WITH grantee IN (SELECT username FROM dba_users WHERE oracle_maintaine d = 'N') CONNECT BY PRIOR granted_role = grantee;`

A.5.33 Protección de registros	Auditoría unificada en AUDSYS, protegida contra DML. Retención móvil de 365 días con DBMS_AUDIT_MGMT y un job diario. Solo AUDIT_ADMIN puede purgar.	`SELECT job_name, job_status FROM dba_audit_mgmt_cleanup_jobs;`
		
		`SELECT audit_trail, last_archive_ts FROM dba_audit_mgmt_last_arch_ts;`

A.8.2 Derechos de acceso privilegiado	Separación de funciones: SYSBACKUP para respaldos (C##BACKUP_OP) y SYSKM para llaves (C##KEY_ADMIN). Rol DBA solo en SYS y SYSTEM. El DBA junior no tiene privilegios ANY.	`SELECT username, sysdba, sysbackup, syskm FROM v$pwfile_users;`
		
		`SELECT grantee FROM dba_role_privs WHERE granted_role = 'DBA';`

A.8.3 Restricción del acceso a la información	Virtual Private Database (DBMS_RLS): el analista solo ve clientes de HEREDIA en SELECT, INSERT, UPDATE y DELETE.	`SELECT policy_name, function, sel, ins, upd, del, enable FROM dba_policies WHERE object_owner = 'APP_CONF';`
A.8.5 Autenticación segura	Bloqueo de 1 hora tras 3 intentos, solo verificadores 12C (SQLNET.ALLOWED_LOGON_VERSION_SERVER = 12a) e intentos fallidos auditados.	`SELECT username, password_versions FROM dba_users WHERE oracle_maintained = 'N';`

A.8.10 Eliminación de información	Supresión del titular por procedimiento (el operador no tiene DELETE), purga por plazo de 5 años, registro con hash SHA-256 y papelera purgada. El residuo queda en un tablespace cifrado.	`SELECT tipo, COUNT(*) FROM app_conf.registro_supresiones GROUP BY tipo;`
		
		`SELECT COUNT(*) FROM dba_recyclebin WHERE owner = 'APP_CONF';`

A.8.11 Enmascaramiento de datos	Data Redaction (DBMS_REDACT): cédula, teléfono y tarjeta en forma parcial, salario total y correo por expresión regular. Quedan exentos el operador (por rol) y los procedimientos del esquema dueño. DEV usa enmascaramiento estático.	`SELECT column_name, function_type, function_parameters FROM redaction_columns WHERE object_owner = 'APP_CONF';`

A.8.12 Prevención de fuga de datos	Exportaciones con Data Pump auditadas. Ninguna cuenta de aplicación tiene EXEMPT REDACTION POLICY ni exportación completa. El analista no puede crear tablas. Respaldos cifrados.	`SELECT grantee, privilege FROM dba_sys_privs WHERE privilege IN ('EXEMPT REDACTION POLICY' , 'EXEMPT ACCESS POLICY');`
		
		`SELECT table_name FROM dba_tab_privs WHERE grantee = 'PUBLIC' AND table_name IN ('UTL_FILE','UTL_HTTP', 'UTL_TCP','UTL_SMTP');`

Control	Implementación en Oracle 21c XE	Evidencia observable (consulta)

A.8.13
Copias de seguridad de la información
	RMAN en ARCHIVELOG con cifrado transparente AES256 (llave TDE), autobackup del controlfile, redundancia 2 y RESTORE DATABASE VALIDATE.	`SELECT encrypted, COUNT(*)`
		`FROM v$backup_piece`
		`GROUP BY encrypted;`
		
		`SELECT name, value`
		`FROM v$rman_configuration;`

A.8.15
Registro (logging)
	Políticas unificadas sobre acceso a CLIENTES, cambios de seguridad, exportaciones y logons fallidos.	`SELECT policy_name, enabled_option`
		`FROM audit_unified_enabled_policies;`
		
		`SELECT dbusername, action_name, return_code`
		`FROM unified_audit_trail`
		`WHERE object_schema = 'APP_CONF';`

A.8.20
Seguridad de redes
	sqlnet.ora con cifrado nativo AES256 y checksum SHA256 en modo REQUIRED, lista blanca TCP.INVITED_NODES y SQLNET.EXPIRE_TIME. Equivale al pg_hba.conf de PostgreSQL.	`SELECT network_service_banner`
		`FROM v$session_connect_info`
		`WHERE sid = SYS_CONTEXT('USERENV','SID');`

A.8.24
Uso de criptografía complementario
	Keystore TDE unificado con auto-login (WALLET_ROOT), llave maestra, tablespace TS_CONF_ENC cifrado en AES256 y llave administrada por SYSKM.	`SELECT con_id, status, wallet_type`
		`FROM v$encryption_wallet;`
		
		`SELECT tablespace_name, encrypted`
		`FROM dba_tablespaces;`

A.8.8
Gestión de vulnerabilidades técnicas complementario
	Inventario de versión y parches. XE no recibe Release Updates: se documenta como riesgo aceptado con plan de migración a Oracle Database Free.	`SELECT banner_full FROM v$version;`
		
		`SELECT patch_id, status`
		`FROM dba_registry_sqlpatch;`

A.8.33
Información de prueba complementario
	Esquema APP_CONF_DEV con datos sintéticos derivados de producción; el desarrollador no tiene acceso a producción.	`SELECT COUNT(*)`
		`FROM app_conf_dev.clientes d`
		`JOIN app_conf.clientes p`
		`ON d.cedula = p.cedula;`

4.4 Lista de 15 controles observables por un auditor externo

Cada control puede comprobarlo un auditor sin depender de la palabra del DBA, con una consulta de solo lectura y un criterio de aceptación objetivo.

#	Control	Qué observa el auditor	Se acepta si	Prueba
1	**A.5.12** Clasificación de la información	Catálogo de clasificación y columnas sensibles sin protección	0 columnas CONFIDENCIAL o RESTRINGIDO sin redacción	PRB-21
2	**A.5.15** Control de acceso	Privilegios otorgados directamente a cuentas de usuario	0 filas; las pruebas negativas devuelven ORA-01031	PRB-06, PRB-11
3	**A.5.16** Gestión de identidades	Inventario de cuentas: tipo de autenticación, estado y último acceso	APP_CONF y APP_CONF_DEV con autenticación NONE; 0 cuentas abiertas sin uso en 90 días	Script 20
4	**A.5.17** Información de autenticación	Política de contraseñas y cuentas con contraseña por defecto	Función de complejidad activa; 0 cuentas abiertas con contraseña por defecto	PRB-13
5	**A.5.18** Derechos de acceso	Mapa usuario → roles heredados	Cada usuario solo con el rol de su función y sin ADMIN OPTION	Script 20
6	**A.5.33** Protección de registros	Job de purga, marca de retención y quién administra la auditoría	Job ENABLED; marca ≈ hoy − 365 días; borrado manual rechazado	PRB-07, PRB-15
7	**A.8.2** Derechos de acceso privilegiado	Cuentas con privilegios administrativos y con rol DBA	SYSDBA solo en SYS; 0 usuarios de aplicación con DBA o ANY	PRB-12
8	**A.8.3** Restricción del acceso a la información	Políticas de filas activas y usuarios exentos de ellas	POL_VPD_CLIENTES habilitada; el analista ve solo HEREDIA	PRB-05
9	**A.8.5** Autenticación segura	Versiones de contraseña y bloqueo por intentos	Solo 12C; el cuarto intento devuelve ORA-28000	PRB-10
10	**A.8.10** Eliminación de información	Bitácora de supresiones y papelera de reciclaje	Papelera vacía; 0 clientes fuera de plazo; supresiones registradas con hash	PRB-09
11	**A.8.11** Enmascaramiento de datos	Columnas con redacción y tipo de función aplicada	5 columnas redactadas; el analista ve la cédula como *****0456	PRB-04, PRB-08
12	**A.8.12** Prevención de fuga de datos	Privilegios de exención y paquetes de salida de red otorgados a PUBLIC	Exenciones solo en roles de Oracle; exportaciones auditadas	PRB-06b, PRB-22, PRB-24
13	**A.8.13** Copias de seguridad de la información	Piezas de respaldo cifradas y configuración de RMAN	ENCRYPTED = YES en todas las piezas; VALIDATE sin errores	PRB-16, PRB-17
14	**A.8.15** Registro (logging)	Políticas activas y eventos de acceso a datos confidenciales	Los eventos de las pruebas aparecen con usuario, acción y código de retorno	PRB-14
15	**A.8.20** Seguridad de redes	Cifrado de la sesión TCP y lista de equipos admitidos	Banner AES256 y SHA256; una IP no invitada es rechazada	PRB-18, PRB-19

4.5 Matriz de evaluación

Niveles asignados el 21 de octubre de 2026 a partir de la evidencia de los scripts 20 y 21 (sección 5).

Tarea	Riesgo	Control	Criterio 0–4	Evidencia	Estado
T-04, T-05	R-CONF-03	**A.5.12** Clasificación de la información	**Nivel 3** Nivel 4: Toda columna sensible clasificada y protegida, con verificación automática programada	8 columnas catalogadas; 0 columnas CONFIDENCIAL/RESTRINGIDO sin redacción; etiquetas en el diccionario. Prueba: PRB-21	**Cumple**
T-02	R-CONF-01	**A.5.15** Control de acceso	**Nivel 3** Nivel 4: Acceso solo por roles, confirmado por pruebas negativas automatizadas	Cuentas del laboratorio sin privilegios directos; ORA-01031 en PRB-06 y PRB-09. Hallazgo: TLD_USER, PRUEBA y SEMILLEROS (otros proyectos) con privilegios directos. Prueba: PRB-06, PRB-11	**Cumple**
T-01	R-CONF-01	**A.5.16** Gestión de identidades	**Nivel 3** Nivel 4: Altas y bajas ligadas a un procedimiento formal con revisión registrada	APP_CONF y APP_CONF_DEV con autenticación NONE; 5 cuentas nominativas con PERFIL_CONF. Hallazgo: PDBADMIN y SEMILLEROS sin uso en más de 90 días. Prueba: Script 20	**Cumple**
T-03	R-CONF-01	**A.5.17** Información de autenticación	**Nivel 3** Nivel 4: Política aplicada a todas las cuentas, incluidas las comunes, y revisada cada trimestre	PERFIL_CONF con 9 reglas y ORA12C_STRONG_VERIFY_FUNCTION; 0 cuentas abiertas con contraseña por defecto. Prueba: PRB-13	**Cumple**
T-01, T-02	R-CONF-01	**A.5.18** Derechos de acceso	**Nivel 3** Nivel 4: Revisión periódica programada con aprobación del responsable del dato	Cada usuario del laboratorio hereda solo el rol de su función, sin ADMIN OPTION. Prueba: Script 20	**Cumple**
T-11	R-CONF-05	**A.5.33** Protección de registros	**Nivel 4** Nivel 4: Retención automatizada y verificada; registros que ningún usuario puede alterar	PURGA_AUDIT_CONF ENABLED; marca 21/10/2025 (365 días); DELETE sobre la auditoría rechazado con ORA-01031. Prueba: PRB-07, PRB-15	**Cumple**
T-02	R-CONF-01	**A.8.2** Derechos de acceso privilegiado	**Nivel 3** Nivel 4: Uso de privilegios administrativos auditado y otorgado solo cuando se necesita	SYSDBA solo en SYS; C##BACKUP_OP solo SYSBACKUP; C##KEY_ADMIN solo SYSKM; ninguna cuenta de aplicación con DBA ni ANY. Prueba: PRB-12	**Cumple**
T-05	R-CONF-03	**A.8.3** Restricción del acceso a la información	**Nivel 3** Nivel 4: Filtro por contexto de aplicación en lugar de nombre de usuario, con prueba automatizada	POL_VPD_CLIENTES activa en SEL/INS/UPD/DEL; el analista ve 16 clientes, todos de HEREDIA. Prueba: PRB-05	**Cumple**
T-03, T-09	R-CONF-01	**A.8.5** Autenticación segura	**Nivel 4** Nivel 4: Bloqueo probado y cada intento fallido registrado en auditoría	Cuentas del laboratorio solo 12C; ORA-01017 ×3 y ORA-28000; los 4 intentos quedan auditados. Hallazgo: cuentas de otros proyectos con 11G. Prueba: PRB-10	**Cumple**
T-10	R-CONF-03	**A.8.10** Eliminación de información	**Nivel 3** Nivel 4: Purga programada y procedimiento formal de atención de solicitudes (Ley 8968)	Papelera vacía; 1 purga por retención y 2 supresiones del titular registradas con hash SHA-256; 0 clientes fuera de plazo. Prueba: PRB-09	**Cumple**

Tarea	Riesgo	Control	Criterio 0–4	Evidencia	Estado
T-05, T-12	R-CONF-03	**A.8.11** Enmascaramiento de datos	**Nivel 4** Nivel 4: Redacción probada con usuarios con y sin rol, y DEV sin datos reales	5 columnas redactadas; el analista ve *****0456 y salario 0, el operador ve los datos reales. Prueba: PRB-04, PRB-08	**Cumple**
T-02, T-06, T-12	R-CONF-02	**A.8.12** Prevención de fuga de datos	**Nivel 2** Nivel 4: PUBLIC sin UTL_*; exportaciones bloqueadas salvo cuenta autorizada y con alerta	Copia de datos bloqueada con ORA-28081; exportaciones auditadas. Hallazgo: PUBLIC conserva EXECUTE sobre UTL_FILE, UTL_HTTP, UTL_TCP, UTL_SMTP, UTL_INADDR y DBMS_LDAP. Prueba: PRB-06b, PRB-22, PRB-24	**Parcial**
T-06	R-CONF-02	**A.8.13** Copias de seguridad de la información	**Nivel 3** Nivel 4: Respaldo programado, copia fuera del equipo y restauración de prueba periódica	ARCHIVELOG; ENCRYPTION FOR DATABASE ON (AES256); 5 piezas de hoy cifradas; RESTORE VALIDATE sin errores. Hallazgo: piezas del 14/10 y autobackup de 12:13 sin cifrar. Prueba: PRB-16, PRB-17	**Cumple**
T-07, T-11	R-CONF-05	**A.8.15** Registro (logging)	**Nivel 3** Nivel 4: Eventos enviados a un SIEM con alertas y revisión periódica	6 políticas activas; lecturas, rechazos (2004, 28081) y logons fallidos (1017, 28000) registrados con usuario y hora. Prueba: PRB-14	**Cumple**
T-09	R-CONF-04	**A.8.20** Seguridad de redes	**Nivel 3** Nivel 4: TLS con certificados y monitoreo del listener.log	Sesión TCP con AES256 y SHA256 desde 127.0.0.1; TCP.INVITED_NODES activo. Prueba: PRB-18, PRB-19	**Cumple**
T-04, T-06	R-CONF-02	**A.8.24** Uso de criptografía	**Nivel 3** Nivel 4: Rotación anual de la llave maestra y respaldo del keystore fuera del servidor	Keystore OPEN/AUTOLOGIN en CDB, PDB$SEED y XEPDB1; TS_CONF_ENC cifrado AES256 con las 3 tablas de APP_CONF. Prueba: PRB-01, PRB-02, PRB-03	**Cumple**
T-08	R-CONF-01	**A.8.8** Gestión de vulnerabilidades técnicas	**Nivel 2** Nivel 4: Release Updates trimestrales aplicadas y verificadas	Oracle 21.3.0.0.0 XE sin parches registrados en dba_registry_sqlpatch. Prueba: PRB-23	**Parcial**
T-12	R-CONF-03	**A.8.33** Información de prueba	**Nivel 3** Nivel 4: Refresco de DEV automatizado con enmascaramiento integrado	0 coincidencias de cédula, nombre, correo y tarjeta entre DEV y producción; el desarrollador recibe ORA-00942 en producción. Prueba: PRB-20	**Cumple**

Resumen: 16 controles cumplen (3 de ellos en nivel 4), 2 quedan en estado parcial y ninguno incumple. Madurez media: 3,1 de 4.

4.6 Batería de pruebas

ID	Tipo	Control	Procedimiento	Resultado esperado	Herramienta	Resultado
PRB-01	Configuración	A.8.24	Consultar v$encryption_wallet en CDB$ROOT.	STATUS = OPEN y WALLET_TYPE = AUTOLOGIN en CDB y XEPDB1	SQL Developer	**Conforme**
PRB-02	Configuración	A.8.24	Consultar v$encrypted_tablespaces en XEPDB1.	TS_CONF_ENC con ENCRYPTIONALG = AES256	SQL Developer	**Conforme**
PRB-03	Negativa	A.8.24	ALTER SYSTEM CHECKPOINT; SHUTDOWN IMMEDIATE; en PowerShell: Select-String -Path TS_CONF_ENC01.DBF -Pattern "Zuleyka" -SimpleMatch; luego STARTUP.	0 coincidencias: el texto no es legible en el archivo	SQL*Plus + PowerShell	**Pendiente**
PRB-04	Funcional	A.8.11	Como U_ANALISTA: SELECT de cédula, correo, teléfono, salario y tarjeta.	Cédula *****NNNN, salario 0, tarjeta **********NNNN, correo enmascarado	SQL*Plus (script 21)	**Conforme**
PRB-05	Funcional	A.8.3	Como U_ANALISTA: conteo de clientes por provincia.	Una sola fila: HEREDIA	SQL*Plus (script 21)	**Conforme**
PRB-06	Negativa	A.5.15	Como U_ANALISTA: UPDATE sobre CLIENTES.	ORA-01031: privilegios insuficientes	SQL*Plus (script 21)	**Conforme**
PRB-06b	Negativa	A.8.12	Como U_ANALISTA: CREATE TABLE ... AS SELECT de CLIENTES.	Rechazo con ORA-28081: Data Redaction impide copiar columnas ocultas (o ORA-01031)	SQL*Plus (script 21)	**Conforme**
PRB-07	Negativa	A.5.33	Como U_ANALISTA: SELECT de UNIFIED_AUDIT_TRAIL. Como U_AUDITOR: DELETE de UNIFIED_AUDIT_TRAIL.	ORA-00942 para el analista; error de privilegio o vista de solo lectura para el auditor	SQL*Plus (script 21)	**Conforme**
PRB-08	Funcional	A.8.11	Como U_OPERADOR: SELECT y UPDATE del cliente 901230456.	Datos completos sin enmascarar; 1 fila actualizada	SQL*Plus (script 21)	**Conforme**
PRB-09	Negativa	A.8.10	Como U_OPERADOR: DELETE directo; luego EXEC prc_suprimir_titular.	DELETE rechazado con ORA-01031; el procedimiento suprime y registra el hash	SQL*Plus (script 21)	**Conforme**
PRB-10	Negativa	A.8.5	Tres conexiones de U_ANALISTA con contraseña errónea y una cuarta con la correcta.	ORA-01017 tres veces y ORA-28000 (cuenta bloqueada)	SQL*Plus (script 21)	**Conforme**
PRB-11	Revisión	A.5.15	Listar privilegios de sistema y de objeto otorgados directamente a usuarios.	0 filas	Script 20	**Conforme**
PRB-12	Revisión	A.8.2	Revisar v$pwfile_users y los usuarios con rol DBA.	SYSDBA solo en SYS; SYSBACKUP y SYSKM en sus cuentas dedicadas	Script 20	**Conforme**
PRB-13	Revisión	A.5.17	Cruzar dba_users_with_defpwd con cuentas abiertas.	0 cuentas abiertas con contraseña por defecto	Script 20	**Conforme**
PRB-14	Funcional	A.8.15	Como U_AUDITOR: consultar UNIFIED_AUDIT_TRAIL de los últimos 30 minutos.	SELECT y UPDATE sobre CLIENTES, logons fallidos y ALTER USER del desbloqueo	SQL*Plus (script 21)	**Conforme**
PRB-15	Configuración	A.5.33	Revisar el job de purga, la marca de archivo y el job de retención.	Jobs habilitados; marca ≈ hoy − 365 días	Script 20	**Conforme**
PRB-16	Configuración	A.8.13	Consultar v$backup_piece después del respaldo RMAN.	ENCRYPTED = YES en todas las piezas disponibles	RMAN + SQL Developer	**Conforme**

ID	Tipo	Control	Procedimiento	Resultado esperado	Herramienta	Resultado
PRB-17	Funcional	A.8.13	RESTORE DATABASE VALIDATE en RMAN.	Finaliza sin errores: el respaldo cifrado es restaurable	RMAN	**Conforme**
PRB-18	Configuración	A.8.20	Por TCP, consultar v$session_connect_info de la propia sesión.	AES256 Encryption service adapter y SHA256 Crypto-checksumming	SQL*Plus (script 21)	**Conforme**
PRB-19	Negativa	A.8.20	Conectar al puerto 1521 desde una IP fuera de TCP.INVITED_NODES (otra PC o WSL).	Conexión rechazada; el rechazo queda en listener.log	SQL Developer / PowerShell	**Pendiente**
PRB-20	Funcional	A.8.33	Como U_DESARROLLADOR: consultar PROD y DEV; cruzar DEV con PROD.	ORA-00942 en PROD; 0 coincidencias de datos reales en DEV	SQL*Plus (scripts 20 y 21)	**Conforme**
PRB-21	Revisión	A.5.12	Cruzar el catálogo de clasificación con redaction_columns.	0 columnas CONFIDENCIAL o RESTRINGIDO sin redacción	Script 20	**Conforme**
PRB-22	Revisión	A.8.12	Listar titulares de EXEMPT REDACTION/ACCESS POLICY y paquetes UTL_* en PUBLIC.	Exenciones solo en roles de Oracle; UTL_* en PUBLIC se reporta como hallazgo	Script 20	**Conforme**
PRB-23	Revisión	A.8.8	Consultar v$version y dba_registry_sqlpatch.	Versión 21c XE sin Release Updates: hallazgo Parcial	Script 20	**Conforme**
PRB-24	Funcional	A.8.12	Ejecutar expdp del esquema APP_CONF_DEV y consultar UNIFIED_AUDIT_TRAIL con AUDIT_TYPE = 'Datapump'.	La exportación aparece auditada con usuario y hora	PowerShell + SQL Developer	**Pendiente**

Las pruebas negativas son conformes cuando Oracle rechaza la acción con el error esperado. PRB-03, PRB-19 y PRB-24 quedaron pendientes: PRB-19 requiere un segundo equipo en la red; PRB-03 y PRB-24 se pueden ejecutar en una sesión posterior.

5. Resultados y evidencias

Las capturas corresponden a la ejecución en el equipo de la estudiante. Las salidas completas están en los archivos de evidencia del repositorio (anexo).

5.1 Cifrado en reposo (A.8.24)

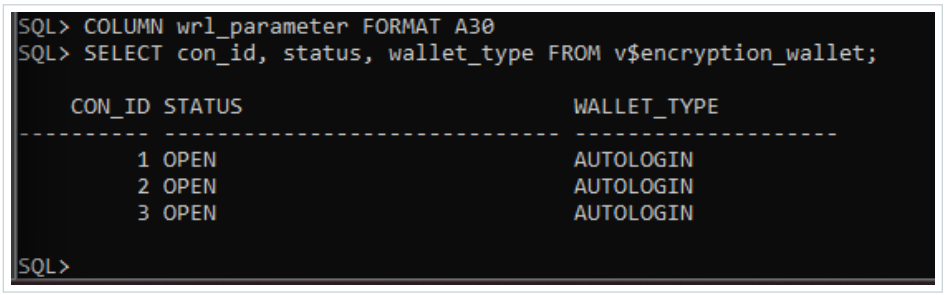


Figura 1. El keystore TDE está abierto con auto-login en CDB$ROOT (1), PDB$SEED (2) y XEPDB1 (3) después de reiniciar la instancia.

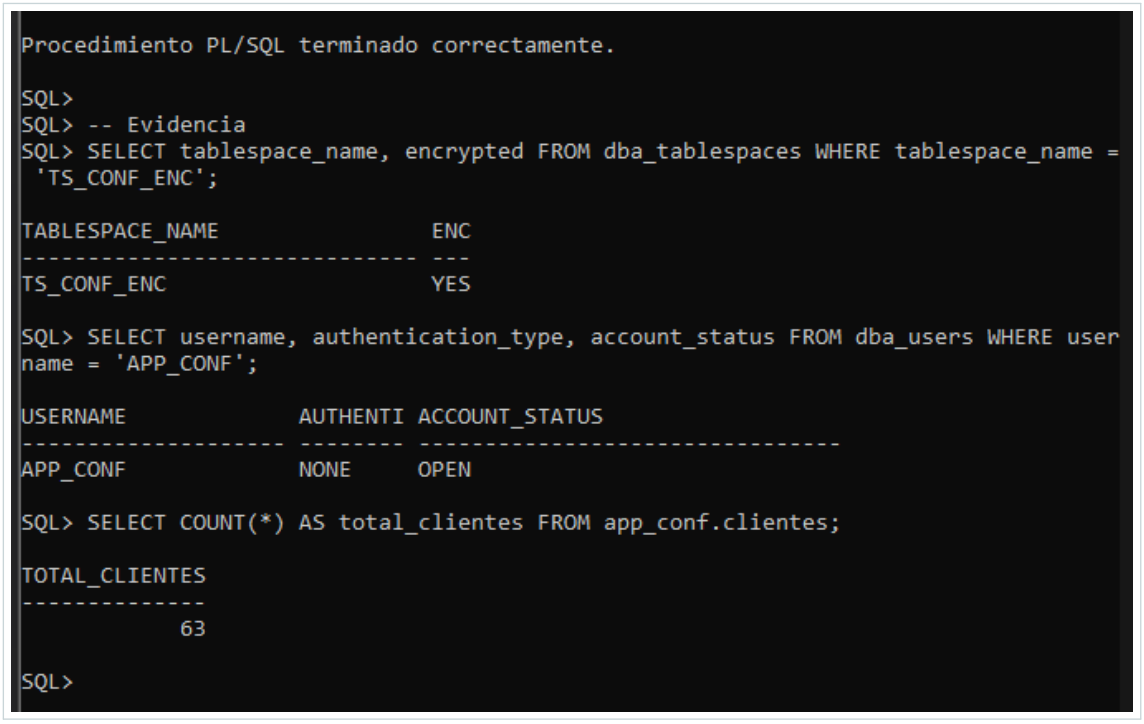
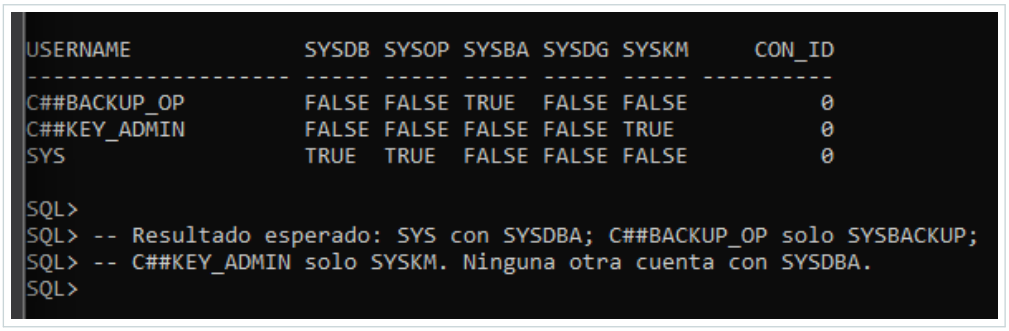


Figura 2. Tablespace TS_CONF_ENC cifrado, esquema APP_CONF con autenticación NONE (nadie puede iniciar sesión como dueño de los datos) y 63 clientes de prueba (A.8.24, A.5.16).

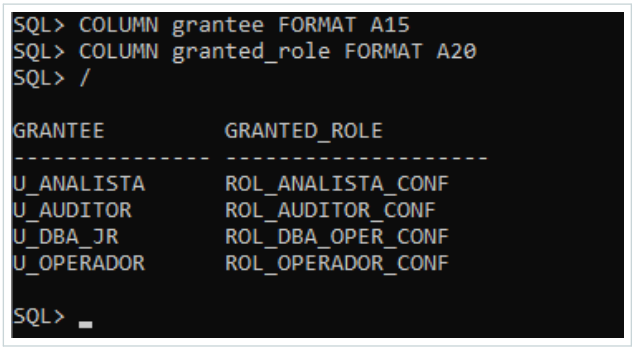
5.2 Acceso privilegiado, roles y autenticación (A.8.2, A.5.15, A.5.18, A.8.5)



```
USERNAME             SYSDB SYSOP SYSBA SYSDG SYSKM     CON_ID
-------------------- ----- ----- ----- ----- ----- ----------
C##BACKUP_OP         FALSE FALSE TRUE  FALSE FALSE          0
C##KEY_ADMIN         FALSE FALSE FALSE FALSE TRUE           0
SYS                  TRUE  TRUE  FALSE FALSE FALSE          0

SQL>
SQL> -- Resultado esperado: SYS con SYSDBA; C##BACKUP_OP solo SYSBACKUP;
SQL> -- C##KEY_ADMIN solo SYSKM. Ninguna otra cuenta con SYSDBA.
SQL>
```

Figura 3. Separación de funciones: solo SYS tiene SYSDBA; C##BACKUP_OP solo SYSBACKUP y C##KEY_ADMIN solo SYSKM (A.8.2).

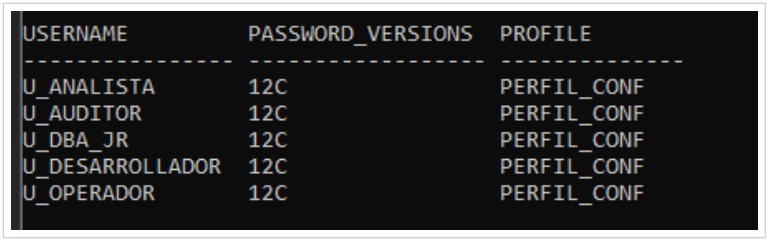


```
SQL> COLUMN grantee FORMAT A15
SQL> COLUMN granted_role FORMAT A20
SQL> /

GRANTEE         GRANTED_ROLE
--------------- --------------------
U_ANALISTA      ROL_ANALISTA_CONF
U_AUDITOR       ROL_AUDITOR_CONF
U_DBA_JR        ROL_DBA_OPER_CONF
U_OPERADOR      ROL_OPERADOR_CONF

SQL> _
```

Figura 4. Cada usuario recibe únicamente el rol de su función; ninguno tiene privilegios directos (A.5.15, A.5.18).



```
USERNAME         PASSWORD_VERSIONS  PROFILE
---------------- ------------------ --------------
U_ANALISTA       12C                PERFIL_CONF
U_AUDITOR        12C                PERFIL_CONF
U_DBA_JR         12C                PERFIL_CONF
U_DESARROLLADOR  12C                PERFIL_CONF
U_OPERADOR       12C                PERFIL_CONF
```

Figura 5. Las cuentas del laboratorio solo tienen verificadores de contraseña 12C y el perfil seguro PERFIL_CONF (A.8.5).

```
SQL> CONNECT u_analista/"Incorrecta#01Ab"@//localhost:1521/XEPDB1
ORA-01017: nombre de usuario/contraseña no válidos; conexión denegada
SQL> CONNECT u_analista/"Incorrecta#02Ab"@//localhost:1521/XEPDB1
ORA-01017: nombre de usuario/contraseña no válidos; conexión denegada
SQL> CONNECT u_analista/"Incorrecta#03Ab"@//localhost:1521/XEPDB1
ORA-01017: nombre de usuario/contraseña no válidos; conexión denegada
SQL> CONNECT u_analista/"(contraseña correcta)"@//localhost:1521/XEPDB1
ORA-28000: La cuenta está bloqueada.
```

Evidencia 1. PRB-10: tras tres intentos fallidos, la cuenta se bloquea aunque el cuarto intento use la contraseña correcta (A.8.5). Fuente: evidencia_pruebas.txt.

5.3 Enmascaramiento y restricción de filas (A.8.11, A.8.3, A.8.12)

```
SQL> -- Conectado como U_ANALISTA
SQL> SELECT cedula, nombre, email, telefono, salario, tarjeta FROM app_conf.clientes WHERE ROWNUM <= 5;
CEDULA     NOMBRE                         EMAIL           TELEFONO  SALARIO TARJETA
---------- ------------------------------ --------------- -------- -------- ----------------
*****0456  Zuleyka Prueba Confidencial  xxxx@correo.cr  ****7777        0 ************4444
*****3701  Sofia Vargas Araya           xxxx@correo.cr  ****6295        0 ************4187
*****1969  Camila Alfaro Rojas          xxxx@correo.cr  ****1355        0 ************3103

SQL> -- Conectado como U_OPERADOR (rol ROL_OPERADOR_CONF, exento de la redacción)
CEDULA     NOMBRE                            SALARIO TARJETA
---------- ------------------------------ ---------- ----------------
901230456  Zuleyka Prueba Confidencial     1850000 4111222233334444
```

Evidencia 2. PRB-04 y PRB-08: el analista ve cédula, teléfono y tarjeta parcialmente ocultos, salario en 0 y correo enmascarado; el operador ve el dato real (A.8.11).

```
SQL> -- U_ANALISTA
SQL> SELECT provincia, COUNT(*) AS clientes FROM app_conf.clientes GROUP BY provincia;
PROVINCIA      CLIENTES
------------ ----------
HEREDIA              16

SQL> CREATE TABLE copia_clientes AS SELECT * FROM app_conf.clientes;
ORA-28081: Privilegios insuficientes: el comando hace referencia a un objeto oculto.
```

Evidencia 3. PRB-05: la política VPD limita al analista a los clientes de Heredia (A.8.3). PRB-06b: Data Redaction impide copiar columnas ocultas a una tabla propia, un canal de fuga (A.8.12).

```
COLUMN_NAME FUNCTION_TYPE       FUNCTION_PARAMETERS
----------- ------------------- ----------------------------------------
CEDULA      PARTIAL REDACTION   VVVVVVVVV,VVVVVVVVV,*,1,5
EMAIL       REGEXP REDACTION
SALARIO     FULL REDACTION
TARJETA     PARTIAL REDACTION   VVVVVVVVVVVVVVVVV,VVVVVVVVVVVVVVVVV,*,1,12
TELEFONO    PARTIAL REDACTION   VVVVVVVV,VVVVVVVV,*,1,4
```

Evidencia 4. Configuración final de la política POL_REDACT_CLIENTES sobre las 5 columnas clasificadas como Confidencial o Restringido (A.8.11, A.5.12). Fuente: evidencia_controles.txt.

5.4 Información de prueba (A.8.33)

```
SQL>
SQL> -- 3. Evidencia: coincidencias de datos reales en DEV (esperado: 0 en todo)
SQL> SELECT
  2    (SELECT COUNT(*) FROM app_conf_dev.clientes d JOIN app_conf.clientes p ON d.cedula  = p.cedula)   AS cedulas_reales,
  3    (SELECT COUNT(*) FROM app_conf_dev.clientes d JOIN app_conf.clientes p ON d.nombre  = p.nombre)   AS nombres_reales,
  4    (SELECT COUNT(*) FROM app_conf_dev.clientes d JOIN app_conf.clientes p ON d.email   = p.email)    AS emails_reales,
  5    (SELECT COUNT(*) FROM app_conf_dev.clientes d JOIN app_conf.clientes p ON d.tarjeta = p.tarjeta) AS tarjetas_reales
  6  FROM dual;

CEDULAS_REALES NOMBRES_REALES EMAILS_REALES TARJETAS_REALES
-------------- -------------- ------------- ---------------
             0              0             0               0

SQL>
SQL> -- El desarrollador no tiene ningun privilegio sobre APP_CONF (esperado: 0)
SQL> SELECT COUNT(*) AS privilegios_dev_en_prod
  2  FROM   dba_tab_privs
  3  WHERE  owner = 'APP_CONF'
  4  AND    grantee IN ('U_DESARROLLADOR','ROL_DESARROLLO_CONF');

PRIVILEGIOS_DEV_EN_PROD
-----------------------
                      0

SQL>
SQL> -- Opcional: exportar DEV con Data Pump cifrado (queda auditado por
SQL> -- POL_AUD_EXPORTACIONES). Desde PowerShell:
SQL> --   expdp system@localhost:1521/XEPDB1 schemas=APP_CONF_DEV `
SQL> --         directory=DATA_PUMP_DIR dumpfile=dev_conf.dmp `
SQL> --         encryption=ALL encryption_mode=TRANSPARENT
SQL> --   (pide la contrasena de SYSTEM; luego revisar el evento en
SQL> --    UNIFIED_AUDIT_TRAIL con AUDIT_TYPE = 'Datapump')
SQL>
```

Figura 6. La copia de desarrollo no comparte ninguna cédula, nombre, correo ni tarjeta con producción, y el desarrollador no tiene privilegios sobre APP_CONF (A.8.33, A.8.11).

5.5 Red cifrada (A.8.20)

```
Copyright (c) 1982, 2021, Oracle.  All rights reserved.

SQL> CONNECT u_auditor/"Jw8#Cd4$Bf2026"@//localhost:1521/XEPDB1
Conectado.
SQL> COLUMN network_service_banner FORMAT A80
SQL> SELECT network_service_banner FROM v$session_connect_info WHERE sid = SYS_CONTEXT('USERENV','SID');

NETWORK_SERVICE_BANNER
--------------------------------------------------------------------------------
Windows NT TCP/IP NT Protocol Adapter for 64-bit Windows: Version 21.0.0.0.0 - P
roduction

Authentication service for 64-bit Windows: Version 21.0.1.0.0 - Production
NTS Authentication service adapter for 64-bit Windows: Version 2.0.0.0.0 - Produ
ction

Encryption service for 64-bit Windows: Version 21.0.1.0.0 - Production
AES256 Encryption service adapter for 64-bit Windows: Version 21.0.1.0.0 - Produ
ction


NETWORK_SERVICE_BANNER
--------------------------------------------------------------------------------
Crypto-checksumming service for 64-bit Windows: Version 21.0.1.0.0 - Production
SHA256 Crypto-checksumming service adapter for 64-bit Windows: Version 21.0.1.0.
0 - Production
```

Figura 7. Una sesión TCP de U_AUDITOR negocia cifrado AES256 e integridad SHA256 con el servidor (A.8.20).

5.6 Auditoría y protección de registros (A.8.15, A.5.33)

```
POLICY_NAME            ENABLED_OPTION  ENTITY_NAME  SUC FAI
---------------------- --------------- ------------ --- ---
ORA_ACCOUNT_MGMT       BY USER         ALL USERS    YES YES
ORA_LOGON_FAILURES     BY USER         ALL USERS    NO  YES
ORA_SECURECONFIG       BY USER         ALL USERS    YES YES
POL_AUD_ADMIN_CONF     BY USER         ALL USERS    YES YES
POL_AUD_DATOS_CONF     BY USER         ALL USERS    YES YES
POL_AUD_EXPORTACIONES  BY USER         ALL USERS    YES YES

HORA     DBUSERNAME       ACTION_NAME  OBJECT_NAME  RETURN_CODE  POLICIES
-------- ---------------- ------------ ------------ -----------  ------------------
13:03:20 U_ANALISTA       SELECT       CLIENTES               0  POL_AUD_DATOS_CONF
13:03:20 U_ANALISTA       UPDATE       CLIENTES            2004  POL_AUD_DATOS_CONF
13:03:20 U_ANALISTA       SELECT       CLIENTES           28081  POL_AUD_DATOS_CONF
13:03:21 U_OPERADOR       DELETE       CLIENTES            2004  POL_AUD_DATOS_CONF
13:03:21 U_DESARROLLADOR  SELECT       CLIENTES            2004  POL_AUD_DATOS_CONF
13:03:22 U_ANALISTA       LOGON                            1017  ORA_LOGON_FAILURES
13:03:25 U_ANALISTA       LOGON                           28000  ORA_LOGON_FAILURES
13:03:26 SYS              ALTER USER   U_ANALISTA              0  ORA_ACCOUNT_MGMT

SQL> -- U_AUDITOR
SQL> DELETE FROM unified_audit_trail WHERE ROWNUM = 1;
ORA-01031: privilegios insuficientes
```

Evidencia 5. PRB-14 y PRB-07b: seis políticas activas; las lecturas, los rechazos y los inicios de sesión fallidos quedan registrados con usuario, hora y código de error; nadie puede borrar los registros (A.8.15, A.5.33). Extracto de evidencia_pruebas.txt.

```
SQL> BEGIN
  2    DBMS_AUDIT_MGMT.SET_LAST_ARCHIVE_TIMESTAMP(
  3      audit_trail_type  => DBMS_AUDIT_MGMT.AUDIT_TRAIL_UNIFIED,
  4      last_archive_time => SYSTIMESTAMP - NUMTODSINTERVAL(365, 'DAY'));
  5
  6    DBMS_AUDIT_MGMT.CREATE_PURGE_JOB(
  7      audit_trail_type           => DBMS_AUDIT_MGMT.AUDIT_TRAIL_UNIFIED,
  8      audit_trail_purge_interval => 24,
  9      audit_trail_purge_name     => 'PURGA_AUDIT_CONF',
 10      use_last_arch_timestamp    => TRUE);
 11
 12    DBMS_SCHEDULER.CREATE_JOB(
 13      job_name        => 'JOB_RETENCION_AUDIT_CONF',
 14      job_type        => 'PLSQL_BLOCK',
 15      job_action      => 'BEGIN DBMS_AUDIT_MGMT.SET_LAST_ARCHIVE_TIMESTAMP('
 16                         || 'DBMS_AUDIT_MGMT.AUDIT_TRAIL_UNIFIED, '
 17                         || 'SYSTIMESTAMP - NUMTODSINTERVAL(365, ''DAY'')); END;',
 18      start_date      => SYSTIMESTAMP,
 19      repeat_interval => 'FREQ=DAILY;BYHOUR=1',
 20      enabled         => TRUE,
 21      comments        => 'A.5.33 - Ventana movil de retencion de auditoria (365 dias)');
 22  END;
 23  /

Procedimiento PL/SQL terminado correctamente.

SQL>
SQL> COLUMN job_name FORMAT A28
SQL> SELECT job_name, job_status, job_frequency FROM dba_audit_mgmt_cleanup_jobs;

JOB_NAME                     JOB_STAT JOB_FREQUENCY
---------------------------- -------- ----------------------------------------------------------------
----------------------------------------
PURGA_AUDIT_CONF             ENABLED  FREQ=HOURLY;INTERVAL=24

SQL> SELECT audit_trail, last_archive_ts FROM dba_audit_mgmt_last_arch_ts;

AUDIT_TRAIL          LAST_ARCHIVE_TS
-------------------- ---------------------------------------------------------------------------
UNIFIED AUDIT TRAIL  21/10/25 12:16:02,354000 +00:00
```

Figura 8. Retención de la auditoría: job de purga diario habilitado y marca de archivo en 21/10/2025, es decir, ventana móvil de 365 días (A.5.33).

5.7 Eliminación segura (A.8.10)

```
SQL> -- U_OPERADOR
SQL> DELETE FROM app_conf.clientes WHERE cedula = '305550111';
ORA-01031: privilegios insuficientes
SQL> EXEC app_conf.prc_suprimir_titular('305550111', 'Solicitud de supresion del titular (Ley 8968)');
Procedimiento PL/SQL terminado correctamente.

TIPO        REGISTROS  ULTIMA
----------  ---------  -------------------------
RETENCION           1  21/10/26 12:20:59
TITULAR             2  21/10/26 13:03:21
OBJETOS_EN_PAPELERA = 0      FUERA_DE_PLAZO = 0
```

Evidencia 6. PRB-09: el borrado directo está prohibido; la supresión solo se hace por procedimiento, que deja registro con el hash SHA-256 de la cédula y no con la cédula (A.8.10, Ley 8968 art. 6 y 7).

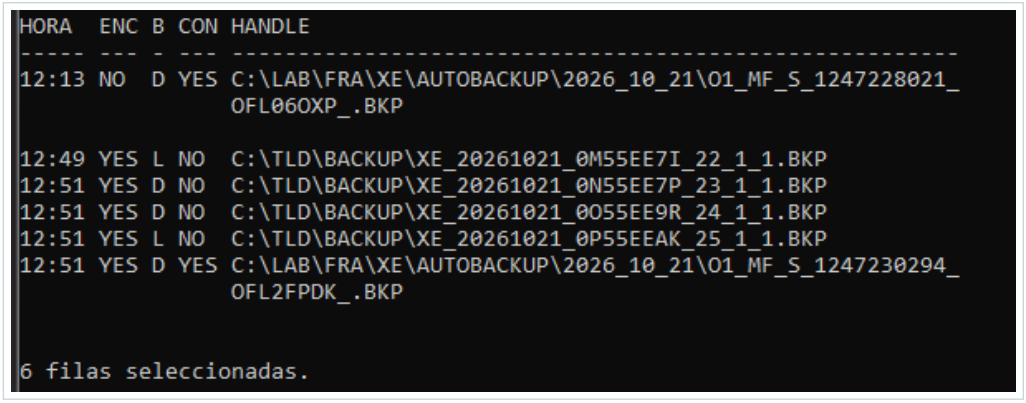
```
SQL> COLUMN ejecutado_por FORMAT A10
SQL> /

TOTAL_CLIENTES
--------------
            62

SQL>
```

Figura 9. Después de la purga por plazo de conservación (más de 5 años sin actividad) quedan 62 clientes (A.8.10).

5.8 Respaldos cifrados (A.8.13)



```
HORA  ENC B CON HANDLE
----- --- - --- ----------------------------------------------------
12:13 NO  D YES C:\LAB\FRA\XE\AUTOBACKUP\2026_10_21\O1_MF_S_1247228021_
                OFL06OXP_.BKP

12:49 YES L NO  C:\TLD\BACKUP\XE_20261021_0M55EE7I_22_1_1.BKP
12:51 YES D NO  C:\TLD\BACKUP\XE_20261021_0N55EE7P_23_1_1.BKP
12:51 YES D NO  C:\TLD\BACKUP\XE_20261021_0O55EE9R_24_1_1.BKP
12:51 YES L NO  C:\TLD\BACKUP\XE_20261021_0P55EEAK_25_1_1.BKP
12:51 YES D YES C:\LAB\FRA\XE\AUTOBACKUP\2026_10_21\O1_MF_S_1247230294_
                OFL2FPDK_.BKP


6 filas seleccionadas.
```

Figura 10. Las piezas del respaldo RMAN del 21/10 están cifradas (ENC = YES). La pieza de las 12:13 es un autobackup del controlfile generado antes de configurar el cifrado de RMAN (ver hallazgo en la sección 6).

La validación `RESTORE DATABASE VALIDATE` terminó sin errores, lo que confirma que los respaldos cifrados son restaurables (PRB-17; evidencia_backup.log). El respaldo se ejecutó con la cuenta C##BACKUP_OP, que solo tiene SYSBACKUP, lo que demuestra también la separación de funciones.

6. Hallazgos y plan de mejora (Actuar)

La verificación encontró problemas reales que impiden llegar al nivel 4 o que están fuera del alcance del laboratorio. Se presentan con la acción propuesta para cerrar cada brecha:

Control	Hallazgo	Acción de mejora	Responsable	Nivel meta
A.8.12	PUBLIC conserva EXECUTE sobre UTL_FILE, UTL_HTTP, UTL_TCP, UTL_SMTP, UTL_INADDR y DBMS_LDAP	Revocar a PUBLIC en CDB$ROOT tras validar dependencias y otorgar solo a cuentas que lo justifiquen; alerta ante exportaciones	DBA	3
A.5.15	TLD_USER, PRUEBA y SEMILLEROS (otros proyectos en la misma PDB) tienen privilegios directos y perfil DEFAULT	Pasar sus privilegios a roles por proyecto y asignarles PERFIL_CONF, coordinando con cada proyecto	DBA	4
A.5.16	PDBADMIN y SEMILLEROS sin uso en más de 90 días	Confirmar con el responsable y bloquear (ACCOUNT LOCK) las cuentas que no se usen	DBA	4
A.8.5	Cuentas de otros proyectos conservan verificadores 11G	Regenerar sus contraseñas ahora que el servidor solo acepta 12C (SQLNET.ALLOWED_LOGON_VERSION_SERVER = 12a)	DBA	4
A.8.13	Respaldos del 14/10 y autobackup de 12:13 sin cifrar; respaldo manual	Eliminar o reemplazar las piezas sin cifrar, programar RMAN y copiar las piezas fuera del equipo	C##BACKUP_OP	4
A.8.8	XE no recibe Release Updates (21.3.0.0.0 sin parches)	Migrar a Oracle Database Free o a una edición con soporte; mientras tanto, aislar la red	DBA / Infraestructura	3
A.8.10	La purga por plazo se ejecuta a mano	Programar PRC_PURGAR_INACTIVOS con DBMS_SCHEDULER y formalizar la atención de solicitudes (Ley 8968)	DBA	4
A.8.15	Sin correlación de eventos	Exportar UNIFIED_AUDIT_TRAIL a un SIEM y definir alertas por lecturas masivas o rechazos repetidos	Seguridad	4
A.8.20	Cifrado nativo en lugar de TLS con certificados; PRB-19 no ejecutada	Configurar TCPS con certificados y probar el rechazo desde una IP no invitada	DBA	4
A.8.24	Sin rotación de llave programada	Rotar la llave maestra cada año (SET KEY ... WITH BACKUP) y resguardar el keystore fuera del servidor	C##KEY_ADMIN	4

Lecciones del proceso

- **El orden importa en el cifrado.** El autobackup de las 12:13 quedó sin cifrar porque Oracle lo generó antes de configurar el cifrado de RMAN. Configurar primero la criptografía evita dejar copias expuestas.
- **Data Redaction tiene reglas estrictas.** El formato enmascarado debe tener la misma longitud que la columna (ORA-28085) y la política alcanza también a los procedimientos del esquema dueño; hubo que ajustar la expresión para que la purga pudiera leer la cédula real.
- **La verificación encuentra lo que la implementación no muestra.** Las cuentas de otros proyectos, los paquetes UTL_* otorgados a PUBLIC y los respaldos antiguos sin cifrar solo aparecieron al ejecutar el script de verificación sobre toda la base.
- **Las pruebas negativas aportan más evidencia.** PRB-06b esperaba ORA-01031 y obtuvo ORA-28081: el enmascaramiento bloqueó la copia antes incluso de revisar el privilegio.

7. Conclusiones

El marco implementado demuestra que los controles de confidencialidad de ISO/IEC 27001:2022 se pueden traducir a configuraciones concretas y verificables en Oracle 21c XE, sin licencias adicionales: TDE y Data Redaction están incluidos en esta edición. De los 18 controles evaluados, 16 cumplen y 2 quedan en estado parcial por limitaciones reales: los privilegios por defecto de PUBLIC y la falta de parches en XE.

La combinación de capas, con red cifrada, cuentas nominativas, roles mínimos, enmascaramiento, VPD, cifrado en reposo y auditoría protegida, hace que ningún control dependa de otro: si una capa falla, las demás siguen protegiendo los datos, como propone la defensa en profundidad. La separación de funciones (SYSBACKUP y SYSKM) reduce además el poder concentrado en el rol DBA.

Por último, el ciclo PHVA resultó útil en la práctica. Los scripts de verificación detectaron hallazgos que no eran visibles durante la implementación, y el plan de mejora convierte esos hallazgos en acciones concretas, que es lo que exige tanto la norma como el artículo 10 de la Ley 8968: medidas de seguridad que se revisan y se actualizan.

8. Uso ético y documentado de inteligencia artificial

En este trabajo se utilizó la herramienta de IA generativa Claude (Anthropic), configurada con el modelo claude-opus-5-5, como asistente durante todo el proceso. La IA generó el análisis inicial, los scripts, el artefacto y el borrador de este informe; la estudiante ejecutó cada script en su propia instalación de Oracle, reportó los resultados y errores, y validó las salidas. La tabla registra los prompts exactos utilizados.

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / corrección de la estudiante	Fuente verificada
Claude (Anthropic)	“necesito hacer eso, analizalo bien” (con el PDF del enunciado adjunto)	Análisis del enunciado: riesgos R-CONF, mapeo de tareas y controles, escala 0–4, y detección de inconsistencias (pg_hba.conf es de PostgreSQL; Dynamic Data Masking es de SQL Server).	Verifiqué en la página oficial de Oracle que TDE y Data Redaction están incluidos en XE 21c. Acepté sustituir pg_hba.conf por sqlnet.ora y agregar A.8.24, A.8.8 y A.8.33 como controles complementarios.	Oracle (s.f.); ISO/IEC 27002:2022
Claude (Anthropic)	“Es individual, para dentro de 4 dias, no tiene nada que ver con TLD”	Generó los scripts SQL y RMAN (01 a 10b, 20, 21 y 99) y el artefacto HTML con las seis tablas.	Ejecuté todos los scripts en mi Oracle 21c XE (21.3) y revisé cada salida. Indiqué el nombre oficial de la tarea para el artefacto.	Salidas de SQL*Plus y RMAN; Oracle (2021a, 2021b, 2021c)
Claude (Anthropic)	Pegué la salida del script 04 con los errores ORA-01917 (“el rol no existe”).	Identificó que un comentario después del punto y coma impedía que SQL*Plus ejecutara CREATE ROLE y dio el bloque corregido.	Ejecuté el bloque y verifiqué en DBA_ROLE_PRIVS que cada usuario tenía su rol.	evidencia_controles.txt (A.5.15, A.5.18)
Claude (Anthropic)	Pegué la salida del script 06 con ORA-06550 / PLS-00103.	Detectó que PL/SQL no acepta INTERVAL '365' DAY(3) y lo reemplazó por NUMTODSINTERVAL.	Comprobé que el job PURGA_AUDIT_CONF quedó ENABLED y la marca de retención en 21/10/2025.	Oracle (2021b); evidencia_controles.txt
Claude (Anthropic)	Pegué la salida del script 07 con ORA-28085.	Explicó que el formato de Data Redaction debía tener la misma longitud que la columna y que la política afectaba al procedimiento de purga; corrigió ambos.	Verifiqué que la purga eliminó 1 registro y que el analista ve la cédula como *****0456.	Oracle (2021a); evidencia_pruebas.txt
Claude (Anthropic)	Pegué la salida de sqlnet.ora y de lsnrctl (líneas con sangría y TNS-01190).	Indicó que las líneas con espacios iniciales se interpretan como continuación, que el listener debía reiniciarse como administrador y que había que admitir el nombre del equipo.	Confirmé en la sesión TCP los adaptadores AES256 y SHA256.	Oracle (2021b); captura de la Figura 7
Claude (Anthropic)	Pegué evidencia_controles.txt con errores SP2-0734 y ORA-00933.	Encontró que las líneas PROMPT que terminaban en guion actuaban como continuación y se comían la consulta siguiente; corrigió el script 20.	Volví a ejecutar el script 20 y revisé que las 18 secciones salieran completas.	evidencia_controles.txt
Claude (Anthropic)	“ok punto por punto que es lo que debo entregar?” y “hazme una lista segun lo que pide el documento, de lo que ya tenemos listo y lo que nos falta y lo que tenemos a medias”	Lista de entregables y estado de avance según las secciones 6, 7, 8 y 10 del enunciado.	La comparé con la sección 10 del enunciado (5 entregables).	Enunciado de la asignación

Herramienta IA	Prompt exacto utilizado	Aporte de la IA	Validación / corrección de la estudiante	Fuente verificada
Claude (Anthropic)	“generame el pdf, recuerda lo del plagio, que debes avisar que tu me ayudaste, lo viste en el documento?”	Redactó este informe (marco teórico, resultados, hallazgos, conclusiones, referencias y esta tabla) e incorporó mis capturas.	Revisé el informe completo y verifiqué las citas de la Ley 8968, su reglamento y las referencias contra las fuentes enlazadas.	Asamblea Legislativa (2011); Poder Ejecutivo (2013); ISO/IEC (2022a, 2022b)
Claude (Anthropic)	“podemos mejorarla? el diseño, por pestañas o no se, veo una pagina muy larga y con colores muy raros, me gustaria mas que sea blanca” y “tal vez un poco mas elaborado el diseño? un poco mas profesional”	Rediseñó el artefacto como página independiente para GitHub Pages, con pestañas por fase PHVA y gráficos de resumen.	Revisé que la página mostrara las seis tablas de la sección 6 del enunciado y que los datos coincidieran con los archivos de evidencia.	evidencia_controles.txt; evidencia_pruebas.txt
Claude (Anthropic)	“que tengo que decir y hacer en el video?” y “dame todo para copiar y pegar”	Preparó el guion del video y los comandos de la demostración en SQL*Plus.	Ejecuté y grabé la demostración en mi Oracle 21c XE; resolví con su guía un ORA-12514 del listener tras reiniciar el equipo.	Video de la demostración

Declaración jurada

Yo, **Jeimy Espinoza Barquero**, declaro que todo contenido generado con IA ha sido declarado en la tabla anterior, validado contra fuentes oficiales (ISO, documentación del motor de BD) y que asumo responsabilidad por su veracidad. Entiendo que omitir esta declaración constituye falta grave.

Jeimy Espinoza Barquero

Firma

Fecha: 27 / 10 / 2026

9. Referencias

Anthropic. (2026). *Claude* (versión claude-opus-5-5) [Modelo de lenguaje de gran tamaño]. https://claude.ai

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley N.° 8968: Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. https://www.micitt.go.cr/sites/default/files/marco_juridico_legal/08.%20Ley%20n.%C2%B0%208968%20Ley%20de%20Protecci%C3%B3n%20de%20la%20Persona%20frente%20al%20tratamiento%20de%20sus%20datos%20personales..pdf

Cuatrecasas. (s.f.). *Information security: ISO/IEC 27001 changes*. https://www.cuatrecasas.com/en/global/technology-digital-media/art/information-security-iso-iec-27001-changes

Delfino.cr. (2026). *Expediente 25826: Ley para proteger a las personas frente a la filtración de sus datos*. https://delfino.cr/asamblea/proyecto/25826

International Organization for Standardization e International Electrotechnical Commission. (2022a). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC 27001:2022). ISO.

International Organization for Standardization e International Electrotechnical Commission. (2022b). *Information security, cybersecurity and privacy protection — Information security controls* (ISO/IEC 27002:2022). ISO.

Joint Task Force. (2020). *Security and privacy controls for information systems and organizations* (NIST Special Publication 800-53, Rev. 5). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-53r5

Kent, K. y Souppaya, M. (2006). *Guide to computer security log management* (NIST Special Publication 800-92). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92

Oracle. (s.f.). *Oracle Database Express Edition*. https://www.oracle.com/xe

Oracle. (2021a). *Oracle Database Advanced Security Guide, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/

Oracle. (2021b). *Oracle Database Security Guide, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/

Oracle. (2021c). *Oracle Database Backup and Recovery User's Guide, 21c*. https://docs.oracle.com/en/database/oracle/oracle-database/21/bradv/

Poder Ejecutivo de la República de Costa Rica. (2013). *Decreto Ejecutivo N.° 37554-JP: Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. La Gaceta, Alcance Digital N.° 42. https://www.tse.go.cr/pdf/normativa/reglamentoleyproteccionpersona.pdf

Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero trust architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Saltzer, J. H. y Schroeder, M. D. (1975). The protection of information in computer systems. *Proceedings of the IEEE, 63*(9), 1278–1308. https://doi.org/10.1109/PROC.1975.9939

Anexo: scripts y archivos de evidencia

Todos los archivos se entregan en el repositorio Git. Las contraseñas de laboratorio de los scripts deben cambiarse antes de usarlos en otro entorno.

Archivo	Función
`01_cdb_tde_keystore.sql`	Keystore TDE, llave maestra y auto-login. Reinicia la base.
`02_cdb_separacion_funciones.sql`	Cuentas comunes con SYSBACKUP y SYSKM.
`03_pdb_esquema_clasificacion.sql`	Tablespace cifrado, esquema sin login, catálogo de clasificación y datos de prueba.
`04_pdb_usuarios_roles_perfiles.sql`	Perfil de contraseñas, roles por función y cuentas nominativas.
`05_pdb_redaction_vpd.sql`	Data Redaction de 5 columnas y política VPD por provincia.
`06_pdb_auditoria_retencion.sql`	Políticas de auditoría unificada y retención de 365 días.
`07_pdb_eliminacion_segura.sql`	Supresión del titular, purga por plazo y bitácora con hash.
`08_pdb_entorno_dev_enmascarado.sql`	Esquema DEV con datos sintéticos y desarrollador aislado.
`09_red_sqlnet_ora.plantilla`	Cifrado de red y lista blanca de IP en sqlnet.ora.
`10a_habilitar_archivelog.sql`	Activa ARCHIVELOG. Reinicia la base.
`10b_backup_cifrado.rman`	Respaldo RMAN cifrado AES256 y RESTORE VALIDATE.
`21_pruebas_funcionales.sql`	Pruebas positivas y negativas por usuario. Genera evidencia_pruebas.txt.
`20_verificacion_controles.sql`	Verificación de los 15 + 3 controles. Genera evidencia_controles.txt.
`99_rollback.sql`	Deshace los scripts 02 a 08 para repetir el laboratorio.
`evidencia_pruebas.txt`	Salida de la batería de pruebas por usuario (script 21).
`evidencia_controles.txt`	Salida de la verificación de los 18 controles (script 20).
`evidencia_backup.log`	Bitácora de RMAN del respaldo cifrado y su validación.